

课程笔记

[LLM Agents F24] Safe AI Agents + AI Policy —Dawn Song

基于公开课程资料整理

Fall 2024



视频作者/频道: Berkeley RDI

发布日期: Fall 2024

视频时长: 约 60 分钟

视 频 链 接: https://www.youtube.com/playlist?list=PLoROMvodv4r0Y23Y0BoGoBGgQ1zmU_MT_

项目主页: <https://github.com/hqh1025/ai-course-notes>

目录

1 引言：AI Agent 安全与治理的紧迫性	2
1.1 本章小结	2
2 AI Agent 的安全威胁	2
2.1 对抗攻击与提示注入	2
2.2 隐私泄露	2
2.3 有害内容生成	2
2.4 本章小结	3
3 安全防护的技术方案	3
3.1 模型层面的安全	3
3.2 系统层面的安全	3
3.3 评估与基准测试	3
3.4 本章小结	3
4 AI 治理与政策	3
4.1 负责任的 AI 评估	3
4.2 监管框架	4
4.3 开放性与安全的平衡	4
4.4 本章小结	4
5 人类-Agent 协作的伦理框架	4
5.1 控制权与自主性的平衡	4
5.2 长期影响	4
5.3 本章小结	4
6 总结与延伸	4
6.1 核心要点	4
6.2 拓展阅读	5

1 引言：AI Agent 安全与治理的紧迫性

Dawn Song 是 UC Berkeley 计算机科学教授，也是 CS294/194-196 课程的主讲人和校园级研究中心 RDI (Center on Responsible Decentralized Intelligence) 的联合主任。作为本系列的收官讲座，她从安全与政策的宏观视角审视 LLM Agent 的发展。

课程总览

本学期的 LLM Agents 课程覆盖了 Agent 系统的全栈：从底层模型能力（推理、规划），到框架与工具（AutoGen、LlamaIndex、DSPy），到应用领域（软件开发、企业 workflows、机器人、科学发现），最终回归到安全与伦理。

1.1 本章小结

LLM Agent 的快速发展使安全问题从学术关切上升为社会紧迫议题，需要技术方案与政策框架同步推进。

2 AI Agent 的安全威胁

2.1 对抗攻击与提示注入

- LLM 容易受到对抗性攻击 (adversarial attacks)，攻击者可通过精心构造的输入使模型产生有害输出。
- Prompt Injection 是 Agent 系统的核心安全威胁：当 Agent 从外部环境（网页、文档、API）获取数据时，恶意内容可能被注入到 Agent 的上下文中，劫持其行为。
- Agent 相比纯 LLM 风险更大——它们拥有执行能力（代码执行、API 调用、文件操作），一旦被劫持后果更严重。

Agent 安全的独特挑战

与传统 LLM 安全不同，Agent 安全不仅涉及模型输出的无害性，还涉及行动的安全性。一个被 prompt injection 劫持的 Agent 可能执行未经授权的操作——发送邮件、修改数据库、泄露隐私信息。

2.2 隐私泄露

- Agent 在执行任务过程中会接触大量用户数据和企业机密
- LLM 可能通过对话泄露训练数据中的隐私信息
- Multi-agent 系统中，Agent 之间的信息流动难以控制

2.3 有害内容生成

Agent 可能被诱导生成或传播有害信息，包括错误信息、歧视性内容或危险指令。

2.4 本章小结

Agent 系统面临的安全威胁覆盖对抗攻击、隐私泄露和有害内容生成三个维度，且由于 Agent 具备执行能力，其安全风险远超传统 LLM。

3 安全防护的技术方案

3.1 模型层面的安全

- **对齐训练 (Alignment)**: 通过 RLHF 等方法使模型遵循人类意图和安全规范
- **Red Teaming**: 系统性地探测模型弱点，发现并修补安全漏洞
- **Constitutional AI**: 让 AI 根据一组原则自我审查和修正输出

3.2 系统层面的安全

分层防御策略

1. **输入过滤**: 检测和过滤可能的 prompt injection 和有害输入
2. **权限控制**: 限制 Agent 的操作权限，遵循最小权限原则
3. **沙箱执行**: 在隔离环境中执行 Agent 的代码和操作
4. **监控审计**: 记录 Agent 的所有行为，支持事后审计和异常检测
5. **人类监督**: 关键操作需要人类确认 (human-in-the-loop)

3.3 评估与基准测试

- 需要专门针对 Agent 安全的评测基准
- 评估不仅要测模型输出的安全性，还要测 Agent 行为链的安全性
- 需要考虑多步交互中的安全性累积风险

3.4 本章小结

Agent 安全需要模型层面和系统层面的分层防御，核心原则是：最小权限、沙箱隔离、人类监督、持续监控。

4 AI 治理与政策

4.1 负责任的 AI 评估

Responsible Scaling Policy (RSP)

以 Anthropic 为代表的 AI 公司提出了 Responsible Scaling Policy，根据模型能力的提升动态调整安全措施的严格程度。核心理念：随着 AI 能力增长，安全措施必须同步升级。

4.2 监管框架

- **EU AI Act**: 欧盟已通过全面的 AI 监管法案，对高风险 AI 系统提出严格要求
- **美国行政令**: 拜登政府发布了 AI 行政令，要求对高能力模型进行安全测试
- **行业自律**: 各大 AI 公司推出自愿承诺，但力度和执行效果参差不齐

4.3 开放性与安全的平衡

开源 AI 的双刃剑

开源 AI 模型促进了研究和创新（如 Percy Liang 在第 3 讲所述），但也使安全措施更容易被绕过。如何在保持开放性的同时确保安全，是当前 AI 治理的核心议题之一。

4.4 本章小结

AI 治理需要技术、政策和行业协作的多层次方案。单纯依靠技术对齐或政策监管都不够，需要构建覆盖全链条的治理体系。

5 人类-Agent 协作的伦理框架

5.1 控制权与自主性的平衡

- Agent 应该拥有多大的自主权？何时需要征求人类同意？
- 完全自主的 Agent 效率高但风险大；完全受控的 Agent 安全但价值有限
- 需要根据任务风险等级动态调整人类监督程度

5.2 长期影响

Agent 社会的挑战

随着 Agent 越来越能干，社会面临深层问题：就业替代、权力集中、数字鸿沟、对 AI 系统的过度依赖。这些不仅是技术问题，更是需要全社会共同面对的伦理和制度问题。

5.3 本章小结

人类-Agent 协作需要在效率与安全之间找到平衡，建立动态的监督机制和清晰的责任归属。

6 总结与延伸

6.1 核心要点

1. Agent 安全问题因其执行能力而远超传统 LLM 安全
2. 分层防御（输入过滤、权限控制、沙箱、监控、人类监督）是当前最佳实践
3. AI 治理需要技术方案与政策框架的协同演进

4. 开放性与安全性的平衡是核心张力
5. 人类-Agent 协作需要动态调整自主权边界

6.2 拓展阅读

- Anthropic, “Responsible Scaling Policy,” 2023.
- European Parliament, “EU AI Act,” 2024.
- Greshake et al., “Not What You’ve Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection,” 2023.
- Ruan et al., “Identifying the Risks of LM Agents with an LM-Emulated Sandbox,” 2024.